

PROGRAMA INTEGRAL DE CAPACITACIÓN EN CIBERSEGURIDAD

Tres perspectivas para construir la cultura de seguridad.



Heimdall Threat Advisory

Consultoría en ciberseguridad para empresas

El programa conecta las perspectivas del personal operativo, técnico y directivo para desarrollar una comprensión común de los riesgos de seguridad.

Temario de capacitación

Nivel 1. Usuario general 📄 : PROTEGIENDO NUESTRA INFORMACIÓN EN EL DÍA A DÍA.

Perspectiva del usuario: reconocer y reaccionar.

Enfocado en desarrollar conciencia sobre ingeniería social, suplantación de identidad y otras situaciones que pueden comprometer a una persona u organización.

Introducción. ¿Qué es un ataque real?: Descripción y análisis de un ejemplo de ataque real con el fin de conocer cómo opera un atacante, que herramientas utilizan y reconocer las técnicas de influencia.

Mod 1. Ingeniería social: Aprender a reconocer los métodos de influencia utilizados por los atacantes con el fin de obtener información, cuáles comportamientos suelen aprovechar y que tipo de información personal buscan obtener

Mod 2. Ejemplo de ataque real: Conocer los ataques de suplantación de identidad más utilizados, como han evolucionado incorporando nuevas tecnologías. Finalmente aprender a identificar las banderas rojas de sitios maliciosos y correos o mensajes fraudulentos.

Mod 3. Uso seguro de credenciales: Entender la importancia del uso de contraseñas seguras, conocer las consecuencias en caso de filtración o descifrado y aprender cómo crear una contraseña segura. También conocerá herramientas útiles para mejorar la seguridad como es la autenticación multifactor.

Mod 4. Impacto al negocio: Comprender que un evento de seguridad no afecta únicamente a un área, sino que puede afectar el negocio completo, las operaciones, reputación e incluso la vida personal de los clientes y empleados si se llegan a filtrar datos personales.

Mod 5. Análisis de un caso real: Análisis detallado, paso a paso de un incidente de ciberseguridad que afectó a una de las mayores empresas públicas del estado mexicano. Identificar cada una de las diferentes etapas del incidente, que herramientas se utilizaron, como afectó a la operación y cuáles fueron las consecuencias inmediatas y a largo plazo.

Lecciones aprendidas: Un compendio de lo aprendido, como debe aplicarse en el día a día en nuestra vida personal y como puede utilizarse también en la vida personal.

Conclusiones: Comprender el rol del trabajador como el primer eslabón de la cadena de seguridad y como su participación puede fortalecer o inhabilitar los controles de protección tecnológicos implementados.

Nivel 2. Personal técnico 🛠️ : CREANDO UN PERÍMETRO SEGURO Y RESILIENTE.

Perspectiva del defensor: analizar y fortalecer.

Enfocado en comprender e identificar la superficie de ataque, reconocer condiciones de riesgo y exposición, aprender y aplicar principios de diseño seguro.

Introducción. Conceptos básicos de ciberseguridad: Conocer los principales conceptos relacionados con la ciberseguridad, vulnerabilidades, superficie de ataque y controles de seguridad con el fin de facilitar el proceso de identificación de condiciones de riesgo, sus causas y como solucionarlas.

Mod 1. Reducción de superficie de ataque y visibilidad: Conocer los principales activos que pueden incrementar la superficie de ataque de una organización, identificar sus debilidades, los diferentes métodos de enumeración de condiciones de riesgo.

Mod 2. Principios de diseño seguro: Conocer las principales directrices de seguridad que permiten integrar la protección desde la concepción de un sistema con el fin de eliminar los componentes que no aporten valor operativo y reducir los costos de corrección en etapas posteriores.

Mod 3. Reconocimiento: Aprender que es un proceso de reconocimiento (como un atacante ve la infraestructura desde el exterior), cuales son los diferentes tipos de reconocimiento y como identificarlos, que tipo de información se obtiene con cada uno de ellos y conocer también que tipos de actividades se pueden realizar según el tipo de información obtenida.

Mod 4. Hardening de infraestructura: Conocer el concepto de *bastionado de sistemas*, entender que las configuraciones por defecto están diseñadas para la comodidad y simplicidad, no para la seguridad. Aprender como lograr minimizar la superficie de ataque mediante la aplicación de una serie de actividades simples pero efectivas.

Mod 5. Defensas perimetrales y acceso seguro: Entender los puntos débiles y las fortalezas de cada mecanismo de protección con el fin de lograr que las interacciones entre estos se apoyen entre si en lugar de bloquearse o entorpecerse. También conocer como actividades simples como la vigilancia continua permiten identificar anomalías antes de que se conviertan en incidentes mayores.

Mod 6. El peligro del encadenamiento de errores: Análisis detallado de un escenario que presenta múltiples condiciones de riesgo de severidad baja las cuales pueden encadenarse y lograr el compromiso de un dispositivo aparentemente protegido e incluso el salto a otros dispositivos de la red.

Conclusiones: Comprender que no es necesario conocer a detalle todas las fases y métodos de ataque que los actores maliciosos pueden utilizar, sino reconocer nuestros propios puntos débiles y desarrollar la capacidad de “pensamiento ofensivo”, preguntarnos ¿Cómo puede ser utilizado contra mí?

Recursos de apoyo: Sitios y herramientas útiles para consultar información actualizada y continuar con el aprendizaje.

Nivel 3. Personal ejecutivo 🇲🇪: CIBERSEGURIDAD Y GESTIÓN DE RIESGOS CORPORATIVOS.

Perspectiva de decisión: interpretar, gestionar y decidir.

Enfocado en comprender conceptos de riesgo, criticidad y retorno de inversión en seguridad además, como interpretar información técnica desde una perspectiva organizacional.

Introducción. Conceptos básicos de gestión y gobernanza: Entender y aplicar los conceptos clave tanto de ciberseguridad como de gobernanza, riesgo y cumplimiento (GRC).

Mod 1. Estrategia de negocio y apetito de riesgo: Conocer la definición de *riesgo*, como estos pueden afectar la consecución de los objetivos de la empresa y como determinar el nivel de riesgo que la organización puede tolerar con el fin de lograr sus metas de negocio (*apetito de riesgo, tolerancia y capacidad*), clasificar activos y priorizar eficientemente la inversión.

Mod 2. Gobernanza y toma de decisiones de riesgo: Entender la importancia de un Plan Director De Seguridad para la consecución de los objetivos del negocio y que debe incluir un PDS eficiente. Qué es el Sistema Gestor De Seguridad de la Información y que ventajas proporciona. Entender como se administra un riesgo, que opciones de tratamiento existen y como elegir la mejor opción.

Mod 3. Amenazas dirigidas hacia la Alta Dirección: Conocer las diferentes amenazas dirigidas específicamente a figuras de autoridad y entender como y por que es que la responsabilidad de mantenerse seguros a sí mismos y a la organización recae en ellos con mayor intensidad que en cualquier otro miembro de la organización, así como que herramientas ayudan a mejorar la seguridad organizacional.

Mod 4. Análisis de casos y visibilidad directiva: Entender por qué la alta dirección es el mayor responsable en asegurar que la gestión de riesgos forme parte de la cultura de seguridad y los objetivos del negocio. Mediante el análisis detallado de casos reales, entenderá como actores externos pueden ser la mayor fuente de riesgo para la organización, aprenderá también como solicitar información útil e interpretarla de la mejor manera posible. Finalmente, aprenderá a gestionar eficientemente el proceso de manejo de crisis y comunicación.

Mod 5. Actividades posteriores y aprendizaje organizacional: Identificar las principales actividades posteriores a un incidente de seguridad, que actividades son obligatorias y cuales aportan mayor valor, implementar la cultura de mejora continua al proceso de gestión, como identificar la raíz del problema y como documentar la investigación de la mejor manera posible.

Conclusión. Liderar el riesgo, no la tecnología: Entender el verdadero propósito de la Alta Dirección en el proceso de gestión de riesgos, aplicar los conocimientos adquirido para reducir la incertidumbre, hacer un uso eficiente de los recursos y presupuesto, proporcionar liderazgo, establecer prioridades claras y promover una cultura organizacional basada en la gestión responsable.